

INTEGRATED DIGITAL BUSINESS PLATFORM

Phase 1 — Authentication & Access Control

Document Type	Technical Specification & Project Documentation
Version	1.0 — Initial Draft
Prepared by	Development Team — Intern Batch 2026
Date	01 June 2026
Phase Status	In Development

1. Executive Summary

This document provides a complete technical specification and implementation plan for Phase 1 of the Integrated Digital Business Platform (IDBP). Phase 1 establishes a secure, modular authentication and access control system that will serve as the foundational security layer for the entire ERP platform, including future modules for Purchase Management, Sales Management, and Project Management.

The authentication system has been architected with modularity and long-term scalability as primary design principles. Every component is decoupled and independently replaceable, ensuring that the system can evolve as business requirements grow without requiring a rebuild of the authentication layer.

Key Design Philosophy

Build once, reuse everywhere. The authentication module is designed as a standalone microservice that will authenticate users for all future ERP modules. No future module will require its own login system — they will all delegate authentication to this Phase 1 service.

2. Project Overview

2.1 Business Context

The organisation requires a centralised digital platform serving two primary business verticals:

- Manufacturing Division
- Government Projects Division

The platform comprises a public-facing corporate portal and a secure internal 'Office Use' module for day-to-day business operations. Phase 1 exclusively covers the internal module's authentication infrastructure.

2.2 Phase 1 Objectives

1. Implement a secure, OTP-based login portal accessible from the organisation's home page.
2. Restrict system access strictly to mobile numbers pre-authorised by the Administrator.
3. Provide the Administrator with full lifecycle control over user access (add, modify, remove).

4. Automatically notify the Administrator on every login and logout event with full session metadata.
5. Deliver a modular, API-first architecture ready to serve all future ERP modules without refactoring.

2.3 Project Timeline

Day	Date	Deliverable	Status
Day 1	Day 1	Project setup, Supabase schema design, environment configuration	Pending
Day 2	Day 2	WhatsApp OTP integration (Twilio/WABA API), admin user management module	Pending
Day 3	Day 3	Session management, JWT token issuance, login/logout logic	Pending
Day 4	Day 4	Automated email notifications, admin alert system, audit logging	Pending
Day 5	Day 5	End-to-end testing, documentation finalisation, stakeholder demo	Pending

3. Technology Stack

The following technologies have been selected to ensure performance, developer productivity, cost-efficiency (primarily free-tier), and long-term maintainability as the system scales into a full ERP platform.

Layer	Technology	Purpose	Tier/Cost
Frontend	React + Vite	Login portal, admin dashboard, home page	Free / Open Source
Styling	Tailwind CSS	Responsive UI, mobile-first design	Free / Open Source
Backend	Node.js + Express	REST API, authentication logic, middleware	Free / Open Source
Database	Supabase (PostgreSQL)	User whitelist, session logs, audit trail	Free tier (500MB)
Auth Tokens	JWT (jsonwebtoken)	Stateless session management across modules	Free / Open Source
WhatsApp OTP	Twilio WABA API	OTP delivery via WhatsApp Business	Pay-per-message
Email Alerts	Nodemailer + Gmail SMTP	Admin login/logout notifications	Free (Gmail)
Hosting FE	Vercel	Frontend deployment, CDN	Free tier
Hosting BE	Railway / Render	Backend API deployment	Free tier

Clarification Required — WhatsApp OTP

To send OTPs via WhatsApp, the organisation will need either: (a) a Twilio account with WhatsApp Business API access, or (b) a verified WhatsApp Business Account (WABA) with a linked phone

number. Please confirm which route is preferred and share the API credentials. If a WABA is not yet set up, the team can assist with the onboarding process. Estimated cost: approximately ₹0.35–0.60 per OTP message.

4. System Architecture

4.1 High-Level Architecture

The system follows a three-tier client-server architecture with a clear separation of concerns between the presentation layer, business logic layer, and data layer. This separation is critical for the long-term goal of building a modular ERP — each future module will communicate with this authentication service via well-defined API contracts.

Tier 1 — Frontend	Tier 2 — Backend API	Tier 3 — Data Layer
React + TailwindLogin portalAdmin dashboardHome page	Node.js + ExpressAuth logic, JWTWhatsApp OTPEmail notifications	Supabase (PostgreSQL)User whitelistSession logsAudit trail

4.2 Modularity Design

The authentication service exposes a clean REST API. Future ERP modules (Purchase, Sales, Project Management) will be independent services that call the auth API to validate tokens. This means:

- Adding a new module never requires changes to the authentication code.
- Different modules can have different permission scopes managed through the same auth layer.
- The admin whitelist can be extended to support role-based access control (RBAC) in future phases.
- The JWT token structure is designed to carry module-level permission claims from day one.

5. Database Schema — Supabase (PostgreSQL)

All tables are hosted on Supabase with Row Level Security (RLS) enabled. The schema is designed to support the full ERP scope, not just Phase 1. Tables marked as Phase 2+ are created now with a minimal structure so data migration is not required later.

5.1 Table: authorised_users

Stores mobile numbers that the Administrator has explicitly granted access to the system.

Column	Type	Constraint	Description
id	uuid	PK, auto-gen	Unique identifier for each user record
mobile_number	varchar(15)	UNIQUE, NOT NULL	International format, e.g. +919876543210
display_name	varchar(100)	nullable	Human-readable label set by admin
is_active	boolean	DEFAULT true	Soft-disable without deletion
role	varchar(50)	DEFAULT 'user'	Reserved for RBAC in future phases

Column	Type	Constraint	Description
permissions	jsonb	DEFAULT '{}'	Module-level permissions (future-ready)
added_by	varchar(100)	NOT NULL	Admin identifier who authorised this user
created_at	timestamptz	DEFAULT now()	Record creation timestamp
updated_at	timestamptz	DEFAULT now()	Last modification timestamp

5.2 Table: otp_requests

Stores OTP codes with expiry times. Codes are invalidated immediately on successful verification.

Column	Type	Constraint	Description
id	uuid	PK, auto-gen	Unique OTP request ID
mobile_number	varchar(15)	NOT NULL, INDEX	Target mobile for OTP delivery
otp_code	varchar(10)	NOT NULL	Hashed OTP (never stored as plain text)
expires_at	timestamptz	NOT NULL	5 minutes from creation by default
is_used	boolean	DEFAULT false	Prevents replay attacks after first use
attempts	integer	DEFAULT 0	Tracks failed verification attempts
created_at	timestamptz	DEFAULT now()	Timestamp of OTP generation

5.3 Table: sessions

Records every authenticated session with full audit trail. This table will also serve Purchase, Sales, and Project modules in future phases.

Column	Type	Constraint	Description
id	uuid	PK, auto-gen	Unique session identifier (used in JWT)
user_id	uuid	FK → authorised_users	Links session to authorised user
mobile_number	varchar(15)	NOT NULL	Denormalised for fast admin queries
login_at	timestamptz	NOT NULL	Exact login timestamp
logout_at	timestamptz	nullable	Null if session still active
duration_seconds	integer	nullable	Computed on logout
ip_address	varchar(45)	nullable	Client IP for security auditing
user_agent	text	nullable	Browser/device information
module	varchar(50)	DEFAULT 'office'	Which module was accessed (future-ready)
jwt_jti	varchar(100)	UNIQUE	JWT token ID for invalidation
is_active	boolean	DEFAULT true	False after logout or token expiry

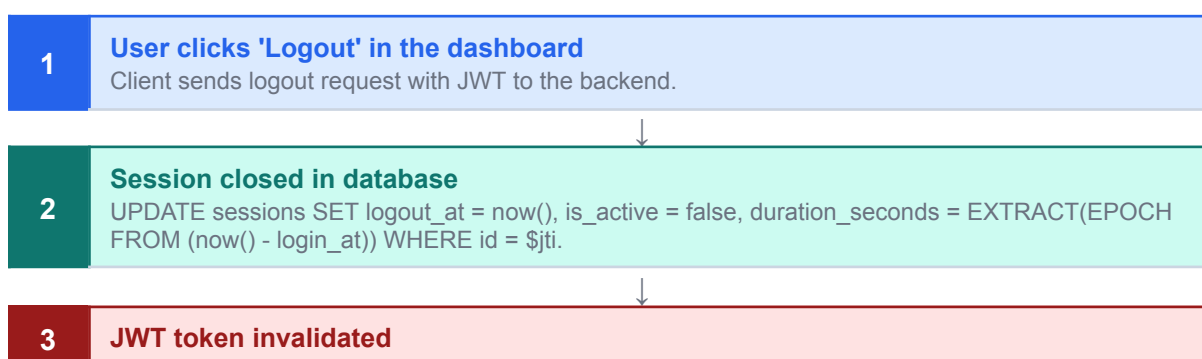
6. Phase 1 — Authentication Flow

6.1 Login Flow

The following step-by-step flow describes the complete process from a user clicking the 'Office Use' button on the home page to gaining access to the internal dashboard.



6.2 Logout Flow



jti added to a blacklist (stored in Supabase). Middleware rejects any future requests with this token even if not yet expired.

4

Admin logout notifications triggered

Email sent with: user mobile, logout date, logout time, total session duration in HH:MM:SS format.

5

Client cookie cleared, redirect to login page

httpOnly cookie removed. User redirected to login portal.

6.3 Admin User Management Flow

The Administrator has exclusive access to a user management panel. No regular user has access to this panel. The panel allows:

6. Add user: Enter mobile number, display name, optional role. System inserts into authorised_users.
7. Deactivate user: Sets is_active = false. User cannot log in but history is preserved.
8. Remove user: Hard delete from authorised_users. All sessions are invalidated.
9. View all users: List with last login time, status, and session count.
10. View audit log: Full session history filterable by user, date range, and duration.

7. API Specification

All endpoints are prefixed with /api/v1/auth. The versioned prefix ensures backward compatibility as the API evolves. All requests and responses use JSON.

Method	Endpoint	Auth Required	Description
POST	/request-otp	None	Validates mobile against whitelist, sends WhatsApp OTP
POST	/verify-otp	None	Verifies OTP code, creates session, returns JWT
POST	/logout	JWT Bearer	Closes session, triggers admin notification
GET	/me	JWT Bearer	Returns current user profile and permissions
GET	/admin/users	Admin JWT	Lists all authorised users with status
POST	/admin/users	Admin JWT	Adds a new authorised mobile number
PATCH	/admin/users/:id	Admin JWT	Updates user details or active status
DELETE	/admin/users/:id	Admin JWT	Removes user and invalidates all sessions
GET	/admin/sessions	Admin JWT	Full session audit log with filters

8. Security Specifications

8.1 OTP Security

- OTP codes are 6 digits, cryptographically random (`crypto.randomInt`).
- Codes are hashed using `bcrypt` before storage — the plain text is never persisted.
- Each OTP expires after 5 minutes and is invalidated immediately after first successful use.
- Maximum 3 verification attempts per OTP before the code is locked and a new one must be requested.
- Rate limiting: maximum 3 OTP requests per mobile number per 15-minute window.

8.2 Session & JWT Security

- JWT tokens are signed with HS256 and a strong secret (minimum 256-bit key stored in environment variables).
- Token expiry: 24 hours. Refresh tokens are out of scope for Phase 1 but the session table supports them.
- Each JWT carries a unique `jti` (JWT ID) matching a sessions row, enabling instant server-side invalidation.
- Tokens are stored in `httpOnly`, `Secure`, `SameSite=Strict` cookies — not in `localStorage`.

8.3 Database Security (Supabase)

- Row Level Security (RLS) enabled on all tables. Users can only read their own session rows.
- Admin routes use a separate admin role verified server-side — never client-side.
- All database credentials stored in environment variables. Never committed to version control.
- Supabase service role key used only on the backend; the anon key is never exposed to the client.

9. Clarifications Required from Management

The following items require confirmation from the organisation before or during development. Responses will directly affect implementation decisions.

#	Item	Details Required
1	WhatsApp Business Account	Does the organisation have an active WABA and Twilio account? If not, we need to initiate onboarding. Please share credentials securely.
2	Admin contact details	Mobile number and email address of the Administrator who will receive login/logout notifications.
3	Email for notifications	Which email account should send the automated notifications? A dedicated address (e.g. <code>noreply@company.com</code>) is recommended.
4	OTP expiry preference	The default is 5 minutes. Should this be adjusted? Shorter = more secure, longer = more user-friendly.
5	Session duration	Default JWT expiry is 24 hours (users stay logged in for one day). Should this be shorter for security?
6	Admin panel access	Should the admin panel be a separate URL/subdomain, or embedded within the same dashboard?
7	Hosting domain	What domain will the platform be deployed on? We need this to configure CORS and cookie policies correctly.
8	Initial authorised users	Please provide the list of mobile numbers to pre-load into the whitelist for initial testing.

10. Sign-off & Acknowledgement

This document represents the agreed scope and technical approach for Phase 1 of the Integrated Digital Business Platform. Please review and confirm, or provide feedback and clarifications via the channels listed.

Prepared by Development Team Intern Batch — 2026 Date: 1/06/2026 Signature: _____	Reviewed by HR / Management S.N Polymers Date: _____ Signature: _____	Approved by Project Sponsor S.N Polymers Date: _____ Signature: _____
--	--	--

Document Status This is Version 1.0 of the Phase 1 Technical Specification. It will be updated following the discussion meeting and any clarifications received from the organisation. All subsequent versions will be tracked with a version number and change log.
--